Autenticação, Autorização e Segurança de Acesso — Homelab

Oct 23, 2026 · @João Victor

O acesso ao homelab é protegido em camadas, no mesmo modelo AAA (Autenticação, Autorização, Auditoria) de uma rede corporativa, só que em escala de casa. Parte já está no `.rsc` do RB5009 (SSH/Winbox restritos à VLAN de gerência, WireGuard, serviços inseguros desligados); o restante abaixo completa o quadro, com uma ordem de implementação por fases ao final.

Autenticação — quem é você

- **VPN primeiro (WireGuard).** O acesso externo só entra pela VPN, com chave por dispositivo (não senha). Revogar um aparelho é remover um peer.
- **SSH com chave, nunca senha.** Desabilitar login por senha e login direto de root. Opcionalmente, chave em token físico (ed25519-sk, FIDO2).
- **MFA / 2FA.** O Proxmox tem TOTP e WebAuthn nativos. Nos hosts Linux, somar TOTP no SSH (`pam_google_authenticator`).
- **Identidade central.** Em vez de usuário solto em cada máquina, um servidor de identidade único:
  - **FreeIPA** — equivalente Linux do AD (Kerberos + LDAP + CA); paralelo direto para quem já usou Active Directory.
  - **LLDAP + Authentik/Authelia** — alternativa mais leve.
- **MikroTik.** Usuário próprio (não o `admin` padrão) e, para centralizar, login via RADIUS apontando para o FreeIPA.

Autorização — o que você pode fazer

O princípio é sempre **menor privilégio**.

- **Proxmox com papéis (RBAC).** Separar quem administra de quem só observa, usando roles nativas (`PVEAuditor`, `PVEVMAdmin`) e pools de VMs. O usuário do dia a dia não precisa ser root do cluster.
- **`sudo` granular** nos hosts, em vez de root para tudo — e registrado em log.
- **Grupos como autorização.** Com FreeIPA/LDAP, o acesso é concedido por grupo (`infra`, `soc`, `leitura`), não por usuário.

- **A rede também é autorização.** As VLANs + firewall já fazem isso na camada 3: só a VLAN de gerência administra os equipamentos.
- **MikroTik.** Grupos de usuário (`full` , `read` , `write`) com restrição de origem (`address=10.10.10.0/24`).

Segurança de acesso — o endurecimento

- **Proxy reverso único com TLS** (Traefik, Caddy ou Nginx) na frente dos serviços web (Grafana, painel do Proxmox), com Authentik/Authelia fazendo *forward auth*: SSO + MFA numa porta só, sem expor cada serviço direto.
- **TLS interno de verdade.** Uma CA própria (ex.: `step-ca`) emitindo certificados, para tudo ser HTTPS em vez de HTTP plano.
- **Bastion / jump host.** Um único ponto de entrada SSH na VLAN de gerência; os outros hosts só aceitam SSH vindo dele.
- **Cofre de segredos.** Senhas e chaves fora de texto plano e fora do Git — do simples (`SOPS` + `age`) ao `Vault` . Chaves do WireGuard e credenciais do `.rsc` entram aqui.
- **HIDS + auditoria.** Wazuh nos hosts (login, integridade de arquivo) + `auditd` , enviando tudo ao SIEM / Security Onion. É o "A" de auditoria do AAA.
- **Fail2ban** nos serviços internos e **atualizações automáticas** de segurança (`unattended-upgrades`).

Camada física / console

- **Senha de BIOS/UEFI** nos ThinkCentre e boot restrito.
- **Criptografia de disco (LUKS)** — essencial no kit portátil que sai de casa; no homelab fixo é opcional, mas bom para o lado forense.

Stack recomendado por fases

Não precisa tudo de uma vez. Uma ordem que funciona, e em que cada etapa já é um item de currículo concreto:

1. **Base:** SSH só com chave + Proxmox com TOTP + usuário restrito no MikroTik.
2. **Centralizar:** FreeIPA (ou LLDAP) como identidade única.
3. **Fachada web:** proxy reverso + Authentik com SSO/MFA + TLS interno.
4. **Fechar o ciclo:** bastion, Vault/SOPS e Wazuh integrado ao SIEM.